Laboratory #5

Lab #5: Craft an Organization-Wide Security Awareness Policy

Learning Objectives and Outcomes

Upon completing this lab, students will be able to complete the following tasks:

- Relate how risks, threats, and software vulnerabilities impact the seven domains of a typical IT infrastructure
- Identify the risks and threats commonly found within the User Domain and Workstation Domain
- Mitigate the risks and threats identified in the User Domain and Workstation Domain by incorporating these topics in the organization's security awareness training program
- Identify the key elements of a security awareness training policy as part of an overall layered security strategy
- Create an organization-wide security awareness training policy mandating annual or periodic security awareness training for new and existing employees

Required Setup and Tools

This is a paper-based lab. Internet access and the student's Microsoft Office applications are needed to perform this lab.

The following summarizes the setup, configuration, and equipment needed to perform Lab #5:

1. Standard onsite student workstation must have the following software applications loaded and Internet access to perform this lab:
    a. Microsoft Office 2007 or higher
    b. Adobe PDF reader
    c. Internet access

Recommended Procedures

Lab #5 – Student Steps:

The following are the steps that the student must follow as part of Lab #5 – Create an Organization-Wide Security Awareness Policy:

1. Review with the class examples of security awareness & training policies found on the Internet: Healthcare: State of North Carolina Department of Health & Human Services http://info.dhhs.state.nc.us/olm/manuals/dhs/pol-80/man/06security_training_and_awareness.pdf

Copyright © 2013 by Jones & Bartlett Learning, LLC, an Ascend Learning Company
www.jblearning.com All Rights Reserved.

Higher-Education: University of Massachusetts
http://www.massachusetts.edu/policyfaq/faq.cfm

U.S. Federal Government: Department of Defense Information Assurance Awareness

http://iase.disa.mil/eta/iaav9/iaa_v9/index.htm

Healthcare: Community Health Care of Washington
http://chpw.org/assets/file/Security-Awareness-and-Training-Policy.pdf

2. Discuss what the risks and threats are within the User Domain per the bulleted list provided:
   - Dealing with humans and human nature
   - User or employee apathy towards information systems security policy
   - Accessing the Internet is like opening "Pandora's box."
   - Surfing the web can be a dangerous trek in unknown territory
   - Opening e-mails and unknown e-mail attachments can lead to malicious software and codes
   - Installing unauthorized applications, files, or data onto organization owned IT assets
   - Downloading applications or software with hidden malicious software or codes
   - Clicking on an unknown URL links with hidden scripts
3. Discuss what organizations can do to mitigate the risks and threats identified within the User Domain
4. Discuss what the risks and threats are within the Workstation Domain per the bulleted list provided:
   - Unauthorized access to workstation
   - Operating system software vulnerabilities
   - Application software vulnerabilities
   - Viruses, Trojans, worms, spyware, malicious software/code, etc.
   - User inserts CDs, DVDs, USB thumb drives with personal data and files onto organization-owned IT assets
   - User downloads unauthorized applications and software onto organization-owned IT assets
   - User installs unauthorized applications and software onto organization-owned IT assets
5. Discuss what organizations can do to mitigate the risks and threats identified within the Workstation Domain
6. Create the deliverables for Lab #5 – Assessment Worksheet

Copyright © 2013 by Jones & Bartlett Learning, LLC, an Ascend Learning Company
www.jblearning.com All Rights Reserved.

7. Answer the Lab #5 – Assessment Questions & Answers that must be submitted with this lab exercise

Deliverables

Upon completion of Lab #5: Create an Organization-Wide Security Awareness Policy, the students must provide the following deliverables as part of this lab:

1. Lab #5 – Security Awareness Training Policy Elements Assessment Worksheet
2. Lab #5 – Create a Security Awareness Training Policy Definition
3. Lab #5 – Assessment Questions & Answers

Evaluation Criteria and Rubrics

The following are the evaluation criteria and rubrics for Lab #5 that the student must conduct:

1. Was the student able to relate how risks, threats, and software vulnerabilities impact the seven domains of a typical IT infrastructure? – [**20%**]
2. Was the student able to identify risks and threats commonly found within the User Domain and Workstation Domain? – [**20%**]
3. Was the student able to mitigate the risks and threats identified in the User Domain and Workstation Domain by incorporating these topics in the organization's security awareness training program? – [**20%**]
4. Was the student able to identify the key elements of a security awareness training policy as part of an overall layered security strategy? – [**20%**]
5. Was the student able to create an organization-wide security awareness training policy mandating annual or periodic security awareness training for new and existing employees? – [**20%**]

Copyright © 2013 by Jones & Bartlett Learning, LLC, an Ascend Learning Company
www.jblearning.com All Rights Reserved.

Lab #5 – Assessment Worksheet

Elements of a Security Awareness & Training Policy

Course Name:	**Policy Development in Information Assurance(IAP301)**
Student Name:	**Phạm Hoàng Hải Nguyên-SE180511**
	Nguyễn Trúc Quỳnh- SE180280
	Giả Thị Nhã Trân- SE180405
Instructor Name	**HaiH5**
Lab Due Date	**03/02/2026**

Overview

For each of the identified risks and threats within the User Domain and Workstation Domain, identify a security control or security countermeasure that can help mitigate the risk or threat.

Risk / Threat Description	Mitigation Tactic / Solution	Implementation & Details
1. Dealing with humans and human nature (curiosity, gullibility, carelessness, malicious intent)	1. Principle of Least Privilege (PoLP) 2. Security Awareness Training (SAT) 3. Foster a Security Culture 4. Physical & Monitoring Controls	❖ **PoLP:** Grant only the minimum access necessary for a user's role to limit damage from compromised accounts. ❖ **SAT:** Conduct regular training (annual + ad-hoc) on phishing, social engineering, and data handling. Use simulated phishing campaigns. ❖ **Culture:** Leadership leads by example, rewards secure behavior, and establishes a blame-free incident reporting channel. ❖ **Controls:** Use badge access, CCTV, Data Loss Prevention (DLP), and User & Entity Behavior Analytics (UEBA) to detect anomalies.
2. User apathy towards information security policies (ignoring or not understanding policies)	1. Make Policies Clear, Accessible & Relevant 2. Workflow Integration 3. Mandatory Acknowledgment & Accountability 4. Explain the “Why”	❖ **Clarity:** Write policies in simple language with real examples. Host them on an accessible internal portal. ❖ **Integration:** Trigger warnings/confirmations when users perform risky actions (e.g., sending large files externally). ❖ **Acknowledgment:** Require digital signatures on Acceptable Use Policies during onboarding and annually. ❖ **Explanation:** Training should explain real-world consequences like breaches, job loss, and reputational damage.
3. Accessing the Internet is like opening “Pandora’s box” (malware, malicious	1. Web Content Filtering 2. Next-Generation Firewall (NGFW) & Intrusion Prevention System (IPS) 3. Network Segmentation 4. Browser	❖ **Filtering:** Block dangerous website categories and maintain allow/deny lists. ❖ **NGFW/IPS:** Inspect traffic to block malicious IPs and exploit attempts.

sites, exploits)	Isolation	❖ **Segmentation:** Separate user networks from critical servers using VLANs or DMZ. ❖ **Isolation:** Use Remote Browser Isolation (RBI) so web code runs in a secure container, not on the endpoint.
4. Surfing the web can be dangerous (unauthorized downloads, malicious ads, spoofed sites)	1. Safe Browsing Training 2. Endpoint Anti-Malware / EDR 3. Application Whitelisting 4. Browser & Plugin Patching	❖ **Training:** Teach users to identify suspicious URLs, avoid unknown ads, and download only from official sources. ❖ **EDR/XDR:** Deploy endpoint detection tools on all workstations for real-time threat prevention. ❖ **Whitelisting:** Allow only approved software on critical systems. ❖ **Patching:** Enforce automatic updates for browsers and plugins to close vulnerabilities.
5. Opening unknown emails/attachments (phishing, ransomware, trojans, macros)	1. Secure Email Gateway (SEG) 2. Anti-Phishing Training 3. Disable Macros & Restrict File Types 4. Verification & Reporting Procedures	❖ **SEG:** Use solutions like Proofpoint or Mimecast to filter spam, phishing, and malware before delivery. ❖ **Training:** Conduct phishing simulations and train users to inspect sender addresses, URLs, and urgent messages. ❖ **Restrictions:** Disable macros from internet files via Group Policy. Block dangerous file types (.exe, .js, .scr). ❖ **Procedures:** Add a “Report Phishing” button and create a clear reporting process to IT/SOC.

Risk / Threat Description	Mitigation Tactic / Solution	Explanation & Implementation Details
1. Unauthorized installation of applications, files, or data on organizational IT assets.	1. Strict Acceptable Use Policy (AUP) & Training 2. Application Whitelisting 3. Removable Media Control 4. Endpoint Anti-Malware (EPP/EDR)	❖ **AUP:** Clearly prohibit installation of unapproved software. Train employees to understand the risks. ❖ **Whitelisting:** Only allow IT-approved applications (from a central software repository) to run. Block all unknown software. ❖ **Device Control:** Disable USB ports via Group Policy, or allow only encrypted and registered USB devices. ❖ **EPP/EDR:** Detect and alert on suspicious software installation behavior.
2. Downloading applications/software containing hidden malware.	1. Web Content Filtering & Secure DNS 2. File Sandboxing 3. Real-time Antivirus Scanning 4. Standard User Accounts	❖ **Web Filtering:** Block access to suspicious software-sharing, crack, or keygen websites. - **Sandboxing:** Downloaded files are automatically opened in an isolated sandbox environment for behavioral analysis before execution. – ❖ **Real-time Scanning:** All downloaded files are instantly scanned by endpoint protection software. ❖ **Standard Accounts:** End users do not have Administrator rights, preventing system-level software installation.
3. Clicking unknown URLs containing malicious code.	1. Phishing Awareness Training 2. Secure Browsers & Browser Isolation 3. Endpoint Protection Tools 4. URL Filtering & Reputation Services	❖ **Training:** Teach users to inspect URLs and avoid clicking suspicious links in email or chat. ❖ **Browser Isolation:** Use Remote Browser Isolation (RBI); all web code runs on a secure server and only a visual stream is sent to the endpoint. ❖ **Endpoint Protection:** Web protection modules block access to known malicious websites. ❖ **URL Filtering:** Integrate with URL reputation databases to block newly identified malicious sites in real time.
4. Unauthorized access to workstations.	1. Strong Authentication 2. Auto-lock Screen	❖ **Authentication:** Require strong passwords or preferably Multi-Factor Authentication (MFA) for login. ❖ **Auto-lock:** Configure screens to lock after 5–10 minutes

	3. Full Disk Encryption (FDE) 4. Physical Access Control	of inactivity, requiring a password to unlock. – ❖ **Encryption:** Use BitLocker (Windows) or FileVault (Mac) to encrypt entire disks. Data remains protected if devices are lost. ❖ **Physical Control:** Encourage employees to lock devices when leaving their desks.
5. Operating system software vulnerabilities.	1. Automated Patch Management 2. Use Supported OS Versions 3. OS Hardening 4. Host-based Firewall	❖ **Patching:** Use WSUS, SCCM, or third-party tools to automatically deploy security patches. ❖ **Supported Versions:** Only use operating systems within vendor support lifecycle (e.g., Windows 10/11, not Windows 7). ❖ **Hardening:** Apply security baselines (e.g., CIS Benchmarks) to disable unnecessary features. ❖ **Host Firewall:** Enable and configure firewalls on each workstation.
6. Application software vulnerabilities.	1. Centralized Application Patch Management 2. Licensed & Legitimate Software 3. Application Whitelisting 4. Sandboxing High-Risk Applications	❖ **Application Patching:** Use tools like Patch My PC or Chocolatey to update Java, Adobe, browsers, etc. – ❖ **Legitimate Software:** Avoid cracked or pirated software, which often contains malware and lacks security updates. – ❖ **Whitelisting:** Block execution of non-approved or vulnerable applications. ❖ **Sandboxing:** Run high-risk applications (e.g., outdated browsers) in isolated environments.
7. Viruses, Trojans, worms, spyware, and malware.	1. Next-Generation Anti-Malware (NGAV/EDR) 2. Behavioral Monitoring 3. Exploit Prevention 4. Frequent Virus Definition Updates	❖ **NGAV/EDR:** Use AI/ML-based solutions to detect unknown malware and support incident response. – ❖ **Monitoring:** Detect abnormal behaviors such as mass file encryption (ransomware). ❖ **Exploit Prevention:** Tools like Microsoft Exploit Guard block vulnerability exploitation techniques. ❖ **Updates:** Ensure threat intelligence databases are

		automatically updated.
8. Users plugging in CD/DVD/USB devices with personal files.	1. Disable Physical Ports/Drives 2. Device Control Policy 3. Automatic Virus Scanning 4. Education & Safe Alternatives	❖ **Disable Ports:** Disable USB and optical drives via BIOS or Group Policy. ❖ **Device Control:** Only allow company-issued USB devices with specific IDs. ❖ **Auto Scanning:** Configure anti-malware software to scan all removable media. ❖ **Education:** Train employees on USB risks and provide secure cloud storage alternatives.
9. Users downloading unauthorized applications/software.	1. Block Software Download Sites 2. Proxy & Web Gateway Policy 3. Host-based IDS (HIDS) 4. Network Traffic Monitoring	❖ **Web Filtering:** Block sites like torrent, crack, and unauthorized download sources. ❖ **Proxy:** Force all web traffic through a proxy for control and logging. ❖ **HIDS:** Alert on unusual executable downloads (.exe, .msi). ❖ **Network Monitoring:** Use SIEM to detect connections to suspicious software-sharing IPs.
10. Users installing unauthorized applications/software.	1. Company Software Portal 2. Automated Software Deployment 3. No Local Admin Rights 4. Event Logging & Auditing	❖ **Software Portal:** Provide an internal portal where employees can request approved software. ❖ **Automated Deployment:** Use SCCM, Intune, or PDQ Deploy to install required software centrally. ❖ **No Admin Rights:** Standard users cannot install system-level software. ❖ **Auditing:** Collect Windows logs for "Process Creation" and "Installation" events to monitor unauthorized installations.

Lab #5 – Assessment Worksheet

Craft an Organization-Wide Security Awareness & Training Policy

Course Name:	**Policy Development in Information Assurance(IAP301)**
Student Name:	**Phạm Hoàng Hải Nguyên-SE180511**
	Nguyễn Trúc Quỳnh- SE180280
	Giả Thị Nhã Trân- SE180405
Instructor Name	**HaiH5**
Lab Due Date	**03/02/2026**

Overview

In this lab, you are to create an organization-wide security awareness & training policy for a mock organization to reflect the demands of a recent compliance law. Here is your scenario:

- Regional ABC Credit union/bank with multiple branches and locations throughout the region
- Online banking and use of the Internet is a strength of your bank given limited human resources
- The customer service department is the most critical business function/operation for the organization
- The organization wants to be in compliance with GLBA and IT security best practices regarding employees in the User Domain and Workstation Domain
- The organization wants to monitor and control use of the Internet by implementing content filtering
- The organization wants to eliminate personal use of organization owned IT assets and systems

- The organization wants to monitor and control use of the e-mail system by implementing e-mail security controls
- Organization wants to implement the security awareness & training policy mandated for all new hires and existing employees. Policy definition to include GLBA and customer privacy data requirements and mandate annual security awareness training for all employees

Instructions

Using Microsoft Word, create a Security Awareness & Training Policy for ABC Credit union/bank capturing the elements of the policy as defined in the Lab #5 – Assessment Worksheet. Use the following policy template for the creation of your Security Awareness & Training Policy definition.

ABC Credit Union

Security Awareness & Training Policy

1. Policy Statement

ABC Credit Union is committed to maintaining a strong security posture by ensuring that all employees understand their responsibilities in protecting information systems and customer data. Human error remains one of the leading causes of security incidents; therefore, this organization establishes a mandatory **Security Awareness & Training Program** as a core component of its layered security strategy.

This policy supports compliance with the **Gramm-Leach-Bliley Act (GLBA)**, industry security best practices, and internal information security standards. It focuses on reducing risks associated with employee behavior in the **User Domain** (human interaction with systems) and the **Workstation Domain** (endpoint devices used by employees). All workforce members are required to participate in ongoing security awareness training to help prevent data breaches, malware infections, phishing attacks, and unauthorized system access.

(Reference: Adaptive Security training policy guide)

https://www.adaptivesecurity.com/blog/security-awareness-training-policy-template-2025-guide

---

2. Purpose & Objectives

The purpose of this policy is to define the requirements for security awareness and training across ABC Credit Union. The objectives of this policy are to:

• Educate employees on cybersecurity threats such as phishing, malware, social engineering, and insider risks

• Promote responsible use of organizational IT assets, email systems, and Internet access

• Protect customer financial and personal data in accordance with GLBA privacy and safeguarding requirements

• Reduce incidents caused by unsafe behaviors such as clicking malicious links or installing unauthorized software

• Ensure all employees understand acceptable use rules and workstation security responsibilities

• Establish a structured, repeatable training program for new hires and existing staff

• Build a culture of security awareness across all branches and departments, especially customer service operations

(Reference: Benchmarking phishing susceptibility reductions)

https://www.hipaajournal.com/study-confirms-security-awareness-training-significantly-reduces-susceptibility-to-phishing-attacks/

---

3. Scope

This policy applies to:

• All full-time and part-time employees

• Contractors, consultants, interns, and temporary staff

• Third-party users with authorized access to ABC Credit Union systems

This policy covers all organizational IT assets, including:

• Workstations (desktops, laptops)

• Mobile devices used for business purposes

• Email systems

• Internet access and web-based services

• Customer information systems and internal applications

Impacted IT Infrastructure Domains:

• **User Domain** – Employees interacting with systems, handling customer data, using email, and browsing the Internet

• **Workstation Domain** – End-user devices that can introduce malware or become entry points for attackers

(Reference: FTC Safeguards Rule Guidance (Official Gov Doc))

https://www.ftc.gov/business-guidance/resources/ftc-safeguards-rule-what-your-business-needs-know

---

4. Standards

This policy aligns with the following standards and requirements:

GLBA Safeguards Rule

Requires financial institutions to implement administrative safeguards, including employee training, to protect customer information.

Workstation Security Standards

All organizational devices must comply with secure configuration requirements, including:

• Operating system updates and patching

• Anti-malware software

• Host-based firewall

• Strong password enforcement

• Screen locking and access controls

Email & Internet Usage Standards

• Content filtering is implemented to reduce exposure to malicious websites

• Email security controls (spam filtering, phishing detection) must be used

• Personal use of organizational IT systems is prohibited

(Reference: Security Awareness Standard)

https://www.usnh.edu/it/departments/cybersecurity/cybersecurity-policies-standards/training-awareness-standard

---

5. Procedures

5.1 New Hire Security Training

All new employees must complete security awareness training before receiving full system access. This training includes:

• Recognizing phishing and malicious emails

• Safe web browsing practices

• Password security and multi-factor authentication

• GLBA data privacy responsibilities

• Reporting security incidents

5.2 Annual Refresher Training

All employees must complete mandatory security awareness training **at least once per year**. Training content will be updated to reflect current threats and policy changes.

5.3 Ongoing Awareness Activities

• Quarterly security reminders or newsletters

• Simulated phishing exercises to reinforce awareness

• Short micro-learning modules on new threats

5.4 Monitoring and Enforcement

• IT security will monitor training completion

• Managers ensure staff compliance

• Non-compliance may result in restricted system access or disciplinary action

(Reference: Implementation strategy & metrics)

https://www.brside.com/blog/security-awareness-training-2025-tools-trends-roi

---

6. Guidelines & Implementation Challenges

- **Implementation Challenges:** Employee engagement and time prioritization from departmental managers may present roadblocks. Some employees may view training as a burden unrelated to their daily tasks.
- **Guidance for Overcoming Challenges:**
  - **Leadership Commitment:** Senior leadership must clearly communicate the importance of the policy and participate in the training themselves.
  - **Relevant Content:** Training scenarios must be based on realistic situations employees encounter, particularly within the Customer Service Department.
  - **Flexibility:** Online training modules allow employees to complete courses in short segments, fitting into busy schedules.
  - **Positive Communication:** Emphasize the benefits of protecting customers and the organization, rather than focusing solely on punitive measures.
  - **Pilot & Feedback:** Conduct a pilot rollout with a small department to refine content and process before organization-wide deployment. Solicit feedback to improve the course.

(Reference: Critical analysis of education methods)

https://www.informatica.si/index.php/informatica/article/view/3328

Note: Your policy document must be no more than 3 pages long.

Lab #5 – Assessment Worksheet

Craft an Organization-Wide Security Awareness & Training Policy

Course Name:	**Policy Development in Information Assurance(IAP301)**
Student Name:	**Phạm Hoàng Hải Nguyên-SE180511**
	Nguyễn Trúc Quỳnh- SE180280
	Giả Thị Nhã Trân- SE180405
Instructor Name	**HaiH5**
Lab Due Date	**03/02/2026**

Overview

In this lab, the students reviewed and identified common risks and threats within the User Domain and Workstation Domain. From this, the elements of a security awareness training policy definition were aligned to policy definition goals and objectives. The students then created a Security Awareness & Training Policy definition focusing on the requirements as defined in the given scenario. This policy, coupled with actual security awareness training content customized to ABC Credit union/bank, can help mitigate the risks and threats within the User Domain and Workstation Domain and will contribute to the organization's overall layered security strategy.

Lab Assessment Questions & Answers

1. How does a security awareness & training policy impact an organization's ability to mitigate risks, threats, and vulnerabilities?

A well-designed security awareness and training policy provides a structured framework for educating employees about cybersecurity threats, how to recognise them, and what actions to take. This formalisation supports consistent messaging across the organisation, leading to measurable reductions in risky behaviours such as clicking phishing emails or mishandling sensitive data. Research shows that when employees receive ongoing awareness training, they demonstrate significantly higher vigilance in identifying threats and engage in more proactive defensive behaviours, ultimately reducing human-related risk exposure at an organisational level.

Reference:

- *https://www.knowbe4.com/press/knowbe4-report-reveals-security-training-reduces-global-phishing-click-rates-by-86*

---

2. Why do you need a security awareness & training policy if you have new hires attend the organisation's security awareness training during orientation?

One-time onboarding training is not sufficient because cybersecurity threats evolve rapidly. Studies and industry guidance recommend **periodic reinforcement** (every 4-6 months) to maintain employee awareness; without refresher training, knowledge fades within months, diminishing the initial training's impact. Therefore, a policy ensures that training is not a one-off event but a **continuous requirement**, keeping staff updated on new threats and best practices.

References:

- *https://gitnux.org/security-awareness-training-statistics/*

---

3. What is the relationship between an Acceptable Use Policy (AUP) and a Security Awareness & Training Policy?

An Acceptable Use Policy (AUP) defines what employees are permitted or prohibited from doing with organisational systems and data, while the security awareness and training policy **teaches employees why those rules matter and how to follow them**. Training helps employees understand the rationale behind technical controls and AUP restrictions, reinforcing compliance and translating policy into everyday secure behaviour.

Reference:

- *https://www.hipaajournal.com/study-confirms-security-awareness-training-significantly-reduces-susceptibility-to-phishing-attacks/*

---

4. Why is it important to prevent users from downloading or installing applications and software found on the Internet?

Downloading and installing unverified software dramatically increases the risk of introducing malware, backdoors, or insecure components into an organisation's network. Comprehensive security training educates staff on these risks and explains why only approved software environments should be used. Trained employees help prevent unintended software installation, which in turn reduces exposure to software-based threats such as malware and ransomware.

Reference:

- *https://www.brside.com/blog/security-awareness-training-statistics-2025-100-studies*

---

5. When trying to combat software vulnerabilities in the Workstation Domain, what is needed most to deal with operating system, application, and other software installations?

Combating workstation vulnerabilities requires **a combination of technical controls and human education**. Patch management and strict software approval processes reduce exposure to exploitable flaws, and training ensures that employees are aware of why updates and managed installations are necessary. This combination of enforcement and education is what reduces workstation-related incidents.

Reference:

- *https://zipdo.co/security-awareness-training-statistics/*

---

6. Why is it important to educate users about the risks, threats, and vulnerabilities found on the Internet and World Wide Web?

Cyber threats such as phishing, ransomware, and social engineering represent the majority of successful attacks worldwide. Educating users equips them with the ability to recognise suspicious links, attachments, and social engineering attempts before they cause harm. Research shows that organisations with formal security awareness training experience significantly fewer breaches because employees actively prevent threats from progressing.

Reference:

- *https://arxiv.org/abs/2510.27298*

7. What are some strategies for preventing users or employees from downloading and installing rogue applications and software found on the Internet?

Effective strategies include:

• Application whitelisting and endpoint restrictions to block unauthorized software

• Regular patching and updates

• Targeted security awareness sessions explaining the risk of unverified software

• Clear communication of policies and consequences for non-compliance

These combined measures build a culture of secure behaviour while reducing the technical risk of rogue applications.

Reference:

- *https://keepnetlabs.com/blog/2024-security-awareness-training-statistics*

---

8. What is one strategy for preventing users from clicking on unknown email attachments and files?

One proven strategy is to incorporate **simulated phishing exercises** into the training program. These simulations expose users to realistic scenarios in a controlled environment, helping them practice identifying suspicious emails and reinforcing safe behaviours. Ongoing simulations combined with feedback significantly reduce actual phishing success rates.

Reference:

- *https://keepnetlabs.com/blog/security-awareness-training-statistics*

---

9. Why should social engineering be included in security awareness training?

Social engineering exploits psychological weaknesses rather than technical flaws, making it one of the most dangerous risk vectors. Training employees about social engineering—such as deceptive emails or phone tactics—enables them to recognise manipulation attempts and report them before damage occurs. This human-centric education is crucial because even the best technical controls cannot block all social exploitation.

Reference:

- *https://www.securitytoday.com/articles/2024/07/16/study-proves-it-security-awareness-training-reduces-phishing-attacks.aspx*

---

10. Which 2 domains of a typical IT infrastructure are the focus of a Security Awareness & Training Policy?

The two primary domains targeted by such policies are:

• **User Domain** – where human decisions directly influence security posture

• **Workstation Domain** – where endpoint systems are most vulnerable to human-induced threats

Focusing on these domains aligns training with the areas where human error most frequently leads to incidents.

Reference:

- *https://www.imssolutionsgroup.com/resources/blog/the-impact-of-security-awareness-training-key-statistics/*

---

11. Why should you include organization-wide policies in employee security awareness training?

Including organisational policies in training ensures that employees understand **not just how to act securely, but why specific rules and expectations exist**. This improves compliance, reduces risky shortcuts, and increases accountability across all roles. Employee adherence to structured policies demonstrated through training leads to fewer security incidents and stronger governance.

Reference:

- *https://arxiv.org/abs/2510.27298*

---

12. Which domain typically acts as the point of entry into the IT infrastructure? Which domain typically acts as the point of entry into the IT infrastructure's systems, applications, databases?

The **User Domain** usually serves as the entry point because employees interact directly with systems and are often targeted first by attackers. The **Workstation Domain** acts as the entry point into internal applications and data stores because endpoints provide access to deeper infrastructure. Focusing training here helps reduce initial compromises and lateral movement after initial breaches.

Reference:

- *https://arxiv.org/abs/2409.01378*

---

13. Why does an organisation need a policy on conducting security awareness training annually and periodically?

Threat landscapes evolve and staff forget content over time, so training must be **ongoing rather than one-time**. Research shows that reinforcement increases retention and mitigates fade-out of skills learned in earlier sessions. A clear policy mandates this consistent schedule, ensuring employees remain alert to emerging attack tactics and up-to-date on protective measures.

Reference:

- *https://arxiv.org/abs/2405.16215*

---

14. What other strategies can organisations implement to keep security awareness top of mind with all employees and authorised users?

Beyond formal training sessions, organisations can promote awareness through:

• Regular security bulletins or newsletters

• Short refresher modules or micro-learning quizzes

• Department-specific guidance and scenario workshops

• Leadership communications that reinforce secure practices

These initiatives keep cybersecurity present in daily work life and encourage employees to think proactively about risks.

Reference:

- *https://www.fortinet.com/products/fortimail-workspace-security*

---

15. Why should an organisation provide updated security awareness training when a new policy is implemented throughout the User Domain or Workstation Domain?

When new policies are introduced, updated training ensures employees understand the changes to expectations, processes, and compliance requirements. Without training that highlights new policy elements, employees may misinterpret or ignore new standards, undermining the policy's effectiveness and leaving security gaps.

Reference:

- *https://www.isaca.org/resources/isaca-journal/issues/2023/volume-2/considerations-for-developing-cybersecurity-awareness-training*